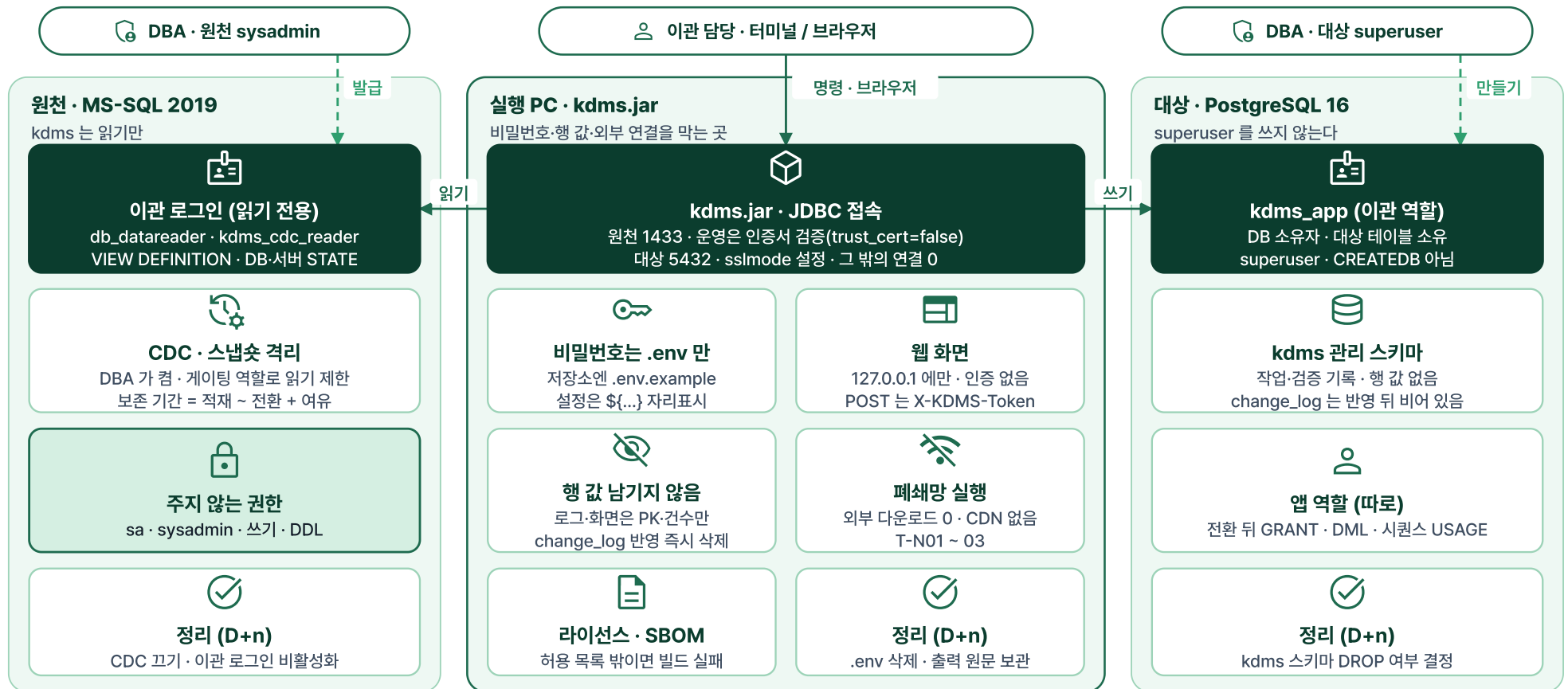


KDMS 보안·권한 설계

KDMS-D10 · v0.1 · 2026-10-10

원천은 읽기만 · 대상은 superuser 아닌 소유자 · 비밀번호는 .env · 행 값은 남기지 않음 · 외부 연결 0



범례 → kdms 접속(JDBC-HTTP) --> 사람이 권한을 준다

웹 화면은 인증이 없다 → 실행 PC 밖으로 열지 않는다(바인딩 변경은 명시적 설정) · 지우는 명령(reset 등)은 화면에 없다
투입 전 확인: 원천 인증서 검증 켜기, 대상 sslmode 값, 이관 로그인 권한 목록을 고객센터 DBA 가 승인

1. 계정과 권한

계정	누가 만드나	권한	주지 않는 것	근거
원천 이관 로그인	원천 DBA	<code>db_datareader</code> , CDC 게이팅 역할 <code>kdms_cdc_reader</code> , <code>cdc</code> 스키마 <code>SELECT</code> , <code>VIEW DEFINITION</code> , <code>VIEW DATABASE STATE</code> , 서버 <code>VIEW SERVER STATE</code> (drain 의 <code>sys.dm_cdc_log_scan_sessions</code> ·Agent 상태)	sa, sysadmin, 쓰기, DDL(Data Definition Language, 정의 언어)	runbook §2.1 ㉔, cdc.md §7, plan R1
원천 DBA	—	sysadmin(또는 RDS(Relational Database Service) 마스터). CDC 켜기·끄기, 스냅샷 격리, 보존 기간, 로그인 발급	kdms 명령은 실행하지 않는다	runbook §0-§2.1
<code>kdms_app</code>	대상 DBA	LOGIN, 이관 DB 소유자. <code>kdms</code> 관리 스키마와 대상 테이블을 만들고 소유	superuser, CREATEDB	runbook §2.2 ㉕
앱 역할	대상 DBA	전환 뒤(runbook §7 ㉔) 테이블 <code>SELECT·INSERT·UPDATE·DELETE</code> , 시퀀스 <code>USAGE</code>	테이블 소유권(소유자는 <code>kdms_app</code>)	runbook §2.2 ㉓·§7 ㉔
대상 DBA	—	superuser. DB·역할 생성, 전환 뒤 트리거·뷰·SP·함수 배포	—	runbook §0

CDC(Change Data Capture, 변경 데이터 캡처)를 켜는 것은 DBA 가 하고, KDMS 로그인은 읽기만 한다. 4단계에서 이 목록으로 동기화가 되는 것을 확인했다(cdc.md §7).

2. 비밀번호와 접속

항목	원칙	근거
비밀번호	<code>.env</code> 또는 환경 변수에만. 저장소에는 <code>.env.example</code> (값 비움)만. 설정 파일은 <code>\${KDMS_SRC_PASSWORD}</code> 같은 자리표시. 명령줄·로그 <code>runs/</code> ·WORKLOG 에 남기지 않는다	CLAUDE.md §2-3
원천 TLS(Transport Layer Security, 전송 암호화)	시험은 자체 서명 인증서라 <code>KDMS_SRC_TRUST_CERT=true</code> . 운영은 <code>false</code> + 인증서 신뢰 저장소	DEC-21, runbook §3

항목	원칙	근거
대상 TLS	<code>KDMS_TGT_SSLMODE</code> (예시 값 <code>prefer</code>). 운영 값은 고객사 정책을 따른다(인증서 검증이 필요하다면 <code>verify-full</code> , 권장이며 시험하지 않음)	<code>.env.example</code>
나가는 연결	원천 1433, 대상 5432 뿐. 실행 중 인터넷 필요 없음	runbook §1, T-N03
정리	이관이 끝나면 실행 PC 의 <code>.env</code> 삭제, 원천 이관 로그인 비활성화	runbook §10

3. 개인정보(행 값)

- 로그·관리 테이블·화면에는 PK 와 건수만 남긴다. 설정으로도 행 값을 켜지 못한다(plan R8).
- 예외는 `kdms.change_log.payload` (변경 행 원문). 반영 트랜잭션 안에서 바로 지운다(DEC-34). 그래서 동기화가 따라잡은 상태면 비어 있다.
- 검증 차이 목록 `kdms.verify_row_diff` 도 PK 와 차이 구분만 둔다(D05).
- 정리 뒤 대상에 남는 `kdms` 기록(`job`, `cutover_run`, `verify_run`, `event_log`)에는 행 값이 없다. 지울지는 DBA 가 정한다(runbook §10).

4. 웹 화면

- 기본 `127.0.0.1` 에만 연다. 인증이 없으므로 LAN 에 열려면 설정을 명시적으로 바꿔야 한다(plan §4.1).
- 상태를 바꾸는 요청(POST)은 `X-KDMS-Token` 헤더가 있어야 한다. CSRF(Cross-Site Request Forgery, 사이트 간 요청 위조)를 막는다(DEC-40).
- 지우는 명령(`reset`, `schema --replace`)은 화면에 없다. 터미널에서만 한다(DEC-40).
- 인증 있는 원격 화면은 MVP 뒤(plan §3.2).

5. 폐쇄망

항목	방법	확인
외부 다운로드 0	라이브러리 전부 jar 에. 화면 JS·CSS·글꼴도 CDN(Content Delivery Network, 외부 배포망) 없이(DEC-09)	T-N01 인터넷 차단 상태 실행, T-N02 jar 안 화면 파일 외부 URL 0, T-N03 실행 중 연결 상대 = 두 DB 뿐. 6단계 리허설 2회 모두 합격 (rehearsal.md, PR #11)
차단 방법(시험)	Mac 방화벽 pf 로 루프백·같은 LAN 만 열고 나머지를 막음 (DEC-49). 차단이 저절로 풀리는 문제가 있어 회차마다 확인 (issues.md E08)	rehearsal.md §2
라이선스	<code>license-maven-plugin</code> : 허용 목록 밖이거나 정보 없으면 빌드 실패. 기록은 licenses.md	빌드
SBOM(Software Bill of Materials, 구성 요소 명세)	<code>cyclonedx-maven-plugin</code> 이 빌드 때 생성	빌드 산출물